

Warsaw, March 6, 2025

Decision

DKN.5112.10.2024

Based on Article 104 § 1 of the Act of June 14, 1960 – Code of Administrative Procedure (Journal of Laws of 2024, item 572) in connection with Article 7 paragraphs 1 and 2, Article 60, Article 90, Article 101, and Article 103 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57 paragraph 1 letters a) and h), Article 58 paragraph 2 letters d) and i), Article 83 paragraphs 1 and 2, and Article 83 paragraph 4 letter a) in connection with Article 24 paragraph 1 and Article 32 paragraphs 1 and 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, as amended), hereinafter referred to as Regulation 2016/679,

after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by J. (...) in M. “(...)” S.A. in liquidation based in M. at (...), the President of the Personal Data Protection Office

I. States the violation by J. (...) in M. “(...)” S.A. in liquidation based in M. at (...) of the provisions of Article 24 paragraph 1 and Article 32 paragraphs 1 and 2 of Regulation 2016/679, consisting of:

- 1) failure to conduct a risk analysis for the processing of personal data in connection with the activities involving the editing, preparation, creation, or publication of press materials;
- 2) non-compliance with the provisions of the “Personal Data Security Policy in J. (...) S.A.” and the “Instructions for Managing Information Systems Used for Processing Personal Data in J. (...) S.A.”;
- 3) failure to implement data security measures ensuring the ability to continuously guarantee the confidentiality, integrity, availability, and resilience of processing systems and services due to:
 - a) lack of clear and transparent rules for handling press materials containing personal data, regulating the obligation to verify these materials before publication regarding the personal data contained therein that could identify natural persons, the publication of which may violate legal provisions or the rights and freedoms of natural persons;
 - b) lack of encryption of media containing personal data used outside the processing area;
- 4) failure to implement appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of personal data.

II. Orders J. (...) in M. “(...)” S.A. in liquidation based in M. to adjust the processing operations to the provisions of Regulation 2016/679, within 60 days from the date of delivery of this decision, by:

- 1) implementing appropriate technical and organizational measures to ensure the ability to continuously guarantee confidentiality, integrity, availability, and resilience of processing systems and services, after conducting a risk analysis, taking into account the state of technical knowledge, cost of implementation, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons, in connection with:
 - a) editing, preparing, creating, and publishing press materials, to define and introduce rules for verifying press materials regarding the personal data contained therein, the publication of which may violate legal provisions or the rights and freedoms of natural persons;
 - b) using media containing data for their processing;
- 2) implementing appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of measures intended to ensure the security of processing.

III. Imposes on J. (...) in M. “(...)” S.A. in liquidation based in M. an administrative fine of 56,824 PLN (in words: fifty-six thousand eight hundred twenty-four zlotys) for the violation of the provisions of Article 32 paragraphs 1 and 2 of Regulation 2016/679.

Justification

1. Authorized by the President of the Personal Data Protection Office (hereinafter referred to as the "President of the Office"), inspectors conducted an inspection at J. (...) in M. "(...)" S.A. in liquidation based in M. at (...) (hereinafter referred to as the "Company" or "Administrator"), to verify compliance of personal data processing with the provisions on personal data protection, i.e., with Regulation 2016/679 and the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the "Act." The inspection covered the technical and organizational measures applied in the Company to ensure that data processing in connection with the activities involving the editing, preparation, creation, or publication of press materials, as defined by the Act of January 26, 1984 – Press Law (Journal of Laws of 2018, item 1914), was carried out in accordance with Regulation 2016/679. The subject of the inspection was to determine the following issues:

- a) Whether appropriate technical and organizational measures have been implemented to ensure that personal data processing is carried out in accordance with Regulation 2016/679, taking into account the nature, scope, context, purposes of processing, and the risk of infringement of the rights and freedoms of natural persons, and in a manner that ensures a level of security appropriate to that risk (Article 32 and Article 24 of Regulation 2016/679).
- b) Whether the implemented technical and organizational measures include appropriate data protection policies, and whether these measures are reviewed and updated as necessary.
- c) Whether the effectiveness of the technical measures intended to ensure the security of processing has been regularly tested, measured, and evaluated (Article 32 paragraph 1 letter d) of Regulation 2016/679).
- d) Whether a risk analysis has been conducted regarding the adopted security measures (Article 32 paragraph 2 of Regulation 2016/679).
- e) Whether actions have been taken to ensure that...

each natural person acting on behalf of the administrator, who has access to personal data, processed it at the request of the administrator (Article 29 and Article 32(4) of Regulation 2016/679).

- f) Was a Data Protection Impact Assessment (DPIA) conducted for data processing processes that may pose a high risk of infringement of rights or freedoms (Article 35 of Regulation 2016/679).

2. During the inspection, oral explanations were obtained from the Company's employees, and an inspection of the premises, devices, and IT systems used for data processing was conducted. Additionally, the inspectors obtained copies of documents relevant to the subject of the inspection, including the "Personal Data Security Policy at J. (...) SA" and the "Instruction for Managing IT Systems Used for Processing Personal Data at J. (...) SA," which are attached to the inspection report.

The factual state established by the inspectors was detailed in the inspection report, which was signed by a person authorized to represent the Company. Based on the evidence gathered, it was determined that in the process of processing personal data, the Company, as the data controller, violated the applicable personal data protection regulations relevant to its activities. These violations consisted of:

- a) Failure to implement the technical and organizational measures developed by the Administrator in the form of policies and instructions – due to non-compliance with their provisions, as evidenced by, among other things, the lack of a risk analysis for data processing processes and the lack of encryption of media used for data processing, as mentioned in the documents "Personal Data Security Policy at J. (...) SA" and "Instruction for Managing IT Systems Used for Processing Personal Data at J. (...) SA."
- b) Failure to conduct a risk analysis for operations involving the processing of personal data in connection with the editing, preparing, creating, or publishing press materials within the meaning of the Press Law, despite the fact that the "Personal Data Security Policy at J. (...) SA" explicitly refers in § 5(4) and (6) to risk analysis as the basis for the designed and maintained personal data security system.
- c) Failure to implement data security measures ensuring the ability to continuously guarantee the confidentiality, integrity, availability, and resilience of processing systems and services – in connection with conducting activities involving the editing, preparing, creating, or publishing press materials, due to:

– the lack of clear and transparent procedures (instructions) for handling press materials containing personal data within the meaning of Article 4(1) of Regulation 2016/679, regulating the obligation to verify materials before publication regarding the personal data contained therein that may identify natural persons, the publication of which may violate legal provisions or the rights and freedoms of natural persons,

– the lack of encryption of media containing personal data transferred outside the processing area.

d) Failure to conduct reviews and updates of the implemented technical and organizational measures.

3. In connection with the above, the President of the Office initiated administrative proceedings in the aforementioned scope to ensure that the Company's processing operations comply with the provisions of Regulation 2016/679. By letter dated September 6, 2024, he notified the Company of the initiation of proceedings. The Company did not respond to the notification of the initiation of administrative proceedings and did not present its position regarding the violation of personal data protection regulations identified by the President of the Office. In response to the notification of the initiation of proceedings, the Company submitted only the annual financial report for the year 2023, including additional information, balance sheet, profit and loss account for the period from January 1, 2023, to December 28, 2023, and additional information, balance sheet, profit and loss account for the period from December 29, 2023, to December 31, 2023.

4. J. (...) in M. "(...)" S.A. in liquidation was entered into the register of entrepreneurs of the National Court Register on (...) July 2002 under number KRS: (...) by the District Court in M., (...) Economic Division of the National Court Register. According to the KRS, the predominant activity of the Company is (...). By Resolution No. 2 of the Extraordinary General Meeting adopted on (...) December 2023, the Company was placed in liquidation. The Administrator also operates a website at [https://\(...\).pl](https://(...).pl), where press materials for (...) are presented.

In this factual state, based on the evidence gathered in the case, the President of the Personal Data Protection Office considered the following:

Violation of the provisions of Article 24(1) and Article 32(1) and (2) of Regulation 2016/679.

5. According to Article 2(1) of the Act, the provisions of Articles 5-9 do not apply to activities involving the editing, preparing, creating, or publishing press materials within the meaning of the Act of January 26, 1984 – Press Law (Journal of Laws of 2018, item 1914), as well as to statements made in the context of literary or artistic activities.

11, Articles 13-16, Articles 18-22, Article 27, Article 28 paragraphs 2-10, and Article 30 of Regulation 2016/679. It should be clarified here that despite the exclusion of the application of the provisions of Regulation 2016/679 indicated in the aforementioned Article 2 paragraph 1 of the Act to activities involving the editing, preparation, creation, or publication of press materials, which is an expression of the legislator's fulfillment of the obligation arising from Article 85 of Regulation 2016/679, the remaining provisions of this regulation apply in this area. Such exclusion does not, therefore, apply to, among others, the obligations of the controller imposed by Article 24 paragraph 1 and Article 32 paragraphs 1 and 2 of Regulation 2016/679.

6. Article 24 paragraph 1 of Regulation 2016/679 indicates that the controller, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity, implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate it. These measures are reviewed and updated as necessary.

7. According to Article 32 paragraph 1 of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity, the controller and the processor implement appropriate technical and organizational measures to ensure a level of security appropriate to that risk, including, where appropriate:

a) pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;
- d) regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

According to paragraph 2 of this article, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those resulting from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

8. It should be indicated, therefore, that the legal basis for the protection of personal data introduced by Regulation 2016/679 includes the obligation to ensure the security of processed data, as specified, among others, in Article 32 paragraph 1 of Regulation 2016/679. This provision introduces a risk-based approach, simultaneously indicating the criteria based on which the controller should select appropriate technical and organizational measures to ensure a level of security corresponding to that risk. In addition to the risk of infringement of the rights or freedoms of natural persons, the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing should also be taken into account. Regulation 2016/679 introduced an approach in which risk management is the foundation of activities related to the protection of personal data and is characterized as a continuous process.

9. The determination of appropriate technical and organizational measures is a two-step process. Firstly, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32 paragraph 1 of Regulation 2016/679, and then to select such technical and organizational measures that will ensure an appropriate level of security in relation to that risk. In appropriate cases, measures such as pseudonymization and encryption of personal data, the ability to ensure ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, as well as regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing should be implemented.

10. The entity that processes personal data is obliged not only to ensure compliance with the guidelines of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. This means that it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk, as well as taking into account the nature of the given organization and the mechanisms used for processing personal data. The controller must conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk. The consequence of such an orientation is the abandonment of lists of requirements regarding security imposed by...

the legislator, for the purpose of independently selecting safeguards based on a threat analysis. Administrators are not provided with specific means and procedures regarding security. The Provincial Administrative Court in Warsaw, in the justification of its judgment of August 26, 2020, case no. II SA/Wa 2826/19, indicated that "(...) This provision [Article 32 of Regulation 2016/679] does not require the data controller to implement any technical and organizational measures that are to constitute means of personal data protection, but requires the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but also the risk associated with the processing of that personal data, which may vary in severity. The adopted measures must be effective; in specific cases, some measures will need to mitigate low risk, while others must mitigate high risk. It is important that all measures (as well as each one individually) are adequate and proportional to the level of risk (...) technical and organizational activities are the responsibility of the personal data controller, but they cannot be selected in a

completely free and voluntary manner, without taking into account the level of risk and the nature of the protected personal data (...)"

11. In light of the above, it should be noted that the risk analysis conducted by the data controller should be documented and justified primarily based on the determination of the factual state existing at the time of its conduct. It is necessary to take into account, in particular, the characteristics of the processes occurring, assets, vulnerabilities, threats, and existing safeguards within the framework of the ongoing personal data processing activities. It is also essential not to overlook the scope and nature of the personal data processed during the activities carried out by the data controller, as the potential negative consequences for the individual in the event of a breach of their personal data protection will depend precisely on the scope and nature of the disclosed data.

12. For the risk analysis to be conducted properly, threats that may arise in the data processing processes should be defined for each asset. The term asset is used to indicate everything that constitutes value for the data controller. Certain assets will have a higher value than others, and they should also be assessed and secured from this perspective. The interconnections of the existing assets are also very important; for example, the confidentiality of assets (personal data) will depend on the type and manner of processing that data. Determining the value of assets is necessary to assess the consequences of a potential incident (breach of personal data protection). It is obvious that a wide range of personal data or the processing of personal data referred to in Article 9(1) or Article 10 of Regulation 2016/679 may cause (in the event of a breach of personal data protection) far-reaching negative consequences for the individuals concerned, and should therefore be assessed as high-value assets, and consequently, the level of their protection should be correspondingly high.

13. The determination of the safeguards applied is necessary, among other things, to avoid duplication. It is also imperative to verify the effectiveness of these safeguards, as the existence of an untested safeguard may first eliminate its value, and second, may create a false sense of security and may result in the omission (failure to detect) a critical vulnerability, which, if exploited, could lead to negative consequences, including in particular a breach of personal data protection. According to the ISO/IEC 27000 standard, a vulnerability is defined as a weakness or gap in security that, if exploited by a given threat, can disrupt operations and may also lead to incidents or breaches of personal data protection. Identifying threats involves determining what threats may arise and from what direction (cause).

14. One method of conducting a risk analysis is, for example, defining the level of risk as the product of the probability and impact of a given incident occurring. The necessity of conducting a risk analysis is also emphasized in case law. In this regard, the Administrative Court in Warsaw stated, among other things, in its judgment of May 13, 2021, case no. II SA/Wa 2129/20, that "The data controller should therefore conduct a risk analysis and assess what threats it is facing." This court similarly expressed itself, among others, in its judgment of October 5, 2023, case no. II SA/Wa 502/23.

15. During the conducted inspection, it was established that within the framework of the adopted organizational measures aimed at ensuring the security of data processing, in order to fulfill the obligations arising from Regulation 2016/679, the Company, by Management Board Resolution No. (...) of (...) December 2018 of the President of the Management Board J. (...) S.A. regarding personal data protection in J. (...) S.A., introduced the "Personal Data Security Policy in J. (...) S.A." as Annex No. 1 to this resolution and the "Instruction for Managing IT Systems Used for Processing Personal Data in J. (...) S.A." as Annex No. 2 to the mentioned resolution. The introduced "Personal Data Security Policy in J. (...) S.A." in § 5(4) indicates that the basis for the designed and maintained personal data security system is a risk analysis conducted.

temporarily to new and changing business processes (data processing activities) that may pose a real threat to the privacy of individuals whose data is processed in the Company; a regular risk assessment (at specified intervals) is conducted in relation to previously analyzed processes in order to update the implemented system solutions and applied safeguards. In § 5 item 6 of the aforementioned document, it is indicated that the risk analysis process is conducted in the manner and scope specified by a separate instruction that is not part of this Policy, within a period not exceeding two years from the last

risk assessment or in the event of a change in the scope and principles of personal data processing within a specific data processing activity.

16. Nevertheless, the conducted control activities revealed that the Company, as the data controller, did not carry out such a risk analysis for the operations of personal data processing related to the activity of editing, preparing, creating, or publishing press materials. Such a risk analysis was also not presented to the supervisory authority in response to the notification of the initiation of administrative proceedings. The provisions of the "Instruction for Managing IT Systems Used for Processing Personal Data in J. (...) S.A." were also not fulfilled, where in point 13 it is stated that devices and media containing personal data transferred outside the processing area must be secured in a manner that ensures the confidentiality and integrity of that data. The implementation of safeguards should occur through the encryption of media containing personal data. However, during the control activities, it was found that (...), smartphones and disks in laptops are not encrypted. The above leads to the conclusion that the Company, despite the introduction, or rather only the development of the "Personal Data Security Policy in J. (...) S.A." and the "Instruction for Managing IT Systems Used for Processing Personal Data in J. (...) S.A.", has not fully implemented them, as the provisions contained therein are not adhered to by the Company. The deficiencies in this regard indicate a violation of the obligations of the controller arising from Article 24(1) and Article 32(1) and (2) of Regulation 2016/679.

17. It should be noted that the aforementioned Article 24(1) of Regulation 2016/679 includes the obligation for the controller to demonstrate that processing is carried out in accordance with Regulation 2016/679, and thus to show that it has fulfilled the obligation to implement "appropriate technical and organizational measures," taking into account the concept of "risk" as significant for each of the criteria that the controller must consider when assessing the appropriateness of such measures, namely: the nature, scope, context, and purpose of processing, as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity of the threat. Furthermore, the cited legal norm requires that the measures used by the controller be reviewed and updated as necessary. Article 32(1) of Regulation 2016/679 elaborates on and specifies the aforementioned general obligations of the controller to ensure the security of processing, indicating the basic technical and organizational measures that the data controller is obliged to implement to ensure an appropriate level of protection. Moreover, when assessing the appropriateness of the level of security of the adopted measures, Article 32(2) of Regulation 2016/679 requires that the controller take into account the risks associated with processing, in particular those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed.

18. Deficiencies in conducting a risk assessment constitute a violation of the aforementioned requirements of Regulation 2016/679 and indicate that the Controller did not identify the threats that may arise in connection with the Company's activities related to editing, preparing, creating, or publishing press materials, nor did it identify the risks for data subjects that may result from this. This, in turn, translates into the inability to assess what technical and organizational measures would be appropriate to the threats arising from data processing. Consequently, without conducting a risk analysis, the Company cannot effectively identify and manage threats, which may lead to violations of the rights or freedoms of individuals whose data is processed. It is unable to demonstrate that the technical and organizational measures it employs to ensure the security of processed data, corresponding to the risk of infringement of the rights or freedoms of those individuals when processing their personal data, are appropriately selected.

19. It should be pointed out that the Press Law in Article 13(2) establishes a prohibition on publishing in the press the image and other personal data of individuals against whom preparatory or judicial proceedings are being conducted, as well as the image and other personal data of witnesses, victims, and injured parties, unless these individuals consent to it. The concept of consent as a condition for the lawful publication of information obtained from individuals providing it is also referenced in Article 14 of the Press Law, which stipulates that the publication or dissemination in any other way of information recorded through audio and visual recordings requires the consent of the individuals providing the

information (section 1). In the further part of this provision...

provides that information and data concerning the private sphere of life may not be published without the consent of the interested party, unless it is directly related to the public activity of that person (sec. 6). The prohibition on publication thus extends to all information relating to an identified or identifiable natural person, as defined in Article 4, point 1 of Regulation 2016/679. According to this provision, "personal data" means any information relating to an identified or identifiable natural person ("data subject"); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, identification number, location data, online identifier, or one or more specific factors characteristic of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person. Compliance with the aforementioned prohibition on publishing personal data under data protection regulations imposes on the data controller the obligation to implement appropriate security measures that ensure the ability to continuously guarantee confidentiality, as well as integrity, availability, and resilience of the systems and services for processing data used in activities related to the editing, preparation, creation, or publication of press materials.

20. During the inspection, it was established that the verification of press materials containing personal data, the publication of which may be subject to restrictions arising from press law, does not take place based on any procedure for handling such materials, as such a procedure or instruction has not been adopted by the Company as the data controller. The Administrator has not defined principles in this regard in any other way either. Although the Company has documentation related to the protection of personal data, regulating, among other things, the obligations of employees when processing personal data, the basic principles of data protection, methods of securing data, or the obligation to maintain confidentiality, i.e., "Data Protection Security Policy at J. (...) S.A.", which employees are familiarized with upon hiring (and the provisions of which, as previously mentioned, are not implemented by the Administrator), the scope of the obligations of employees engaged in the processing of personal data, a declaration of familiarization with the regulations on personal data protection, and the ethical principles of journalism, it cannot be inferred from this documentation any principles regarding the verification of press material prior to its publication, regulating issues such as, for example, the identification of the person or persons responsible within the Company for adhering to the prohibition on publishing data, the method of documenting and verifying consent for publication of data, the method of anonymizing data, etc. The verification of materials is based solely on the organizational structure of the editorial department and the hierarchical subordination of journalists (editors) working in a given editorial office.

21. In the opinion of the President of the Office, the lack of a transparent procedure for verifying press materials intended for publication in terms of their compliance with the law and whether they do not violate the rights or freedoms of natural persons before their publication signifies complete discretion in this regard and a lack of control over whether in each case the publication of press materials occurred after conducting the aforementioned verification. The absence of encryption of devices and media used for processing personal data transmitted outside the processing area, as well as the lack of adopted principles for verifying press materials prior to their publication regarding the personal data contained therein, confirms that the data security measures functioning within the Company do not ensure the ability to continuously guarantee confidentiality, integrity, availability, and resilience of the processing systems and services referred to in Article 32, sec. 1, lit. b) of Regulation 2016/679.

22. Additionally, it was found during the inspection that the "Data Protection Security Policy at J. (...) S.A." developed in 2018 and the "Instruction for Managing Information Systems Used for Processing Personal Data at J. (...) S.A." had not been subject to regular reviews and modifications to ensure their relevance concerning existing processes for processing personal data, including operations for processing personal data in connection with activities related to the editing, preparation, creation, or publication of press materials. This concerns, among other things, issues such as the designation of the administrator of information systems, the list of information systems, the execution of backups, the frequency of password changes, or the security of devices and media containing personal data

transmitted outside the processing area. Such actions had not been undertaken by the Administrator, even though such an obligation was specified in § 15 of the Policy, and additionally supervised by the data protection officer based on § 18 of the adopted "Data Protection Security Policy at J. (...) S.A." The described requirement for reviewing the aforementioned documentation fits into the obligation of the Administrator to conduct regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of personal data processing, as required by Article 32, sec. 1, lit. d) of Regulation 2016/679. The Administrator is obliged to verify both

****Assessment of the Effectiveness of Security Measures****

1. The effectiveness of the security measures applied must be assessed at every stage of processing. The complexity of this verification should be evaluated in terms of adequacy to risks and proportionality concerning the state of technical knowledge, implementation costs, and the nature, scope, context, and purposes of processing. Testing, measuring, and evaluating, in order to fulfill the requirement arising from Article 32(1)(d) of Regulation 2016/679, must be conducted regularly, consciously planned, organized, and documented within specified time frames, regardless of changes in the organization and the course of data processing processes.

2. New risks or threats may materialize or be revealed spontaneously, entirely independently of the administrator, and this fact should also be taken into account both when building the personal data protection system and during its implementation. This, in turn, defines the necessity of conducting regular verification of the entire personal data protection system in terms of both adequacy and effectiveness of the implemented organizational and technical solutions. The assessment of the probability of a given event occurring should not be based solely on the frequency of events in a given organization, as the fact that a particular event has not occurred in the past does not mean that it cannot occur in the future. The necessity for the Administrator to fulfill the discussed obligation was also pointed out by the Provincial Administrative Court in Warsaw (hereinafter referred to as "WSA"), which in its judgment of October 21, 2021, case file II SA/Wa 272/21, indicated that "(...) the President of the UODO was also correct in pointing out in the justification of the challenged decision that the lack of regulations in the procedures adopted by the Company ensuring regular testing, measuring, and evaluating the effectiveness of the applied technical and organizational measures aimed at ensuring data processing security contributed to the occurrence of a personal data breach. The authority also rightly points out that it was demonstrated in the proceedings that the Company did not conduct tests aimed at verifying the security of the application (...) and the WebAPI of the system (...), concerning the vulnerabilities of the IT system related to the occurrence of the personal data breach (...) conducting tests only in the event of an emerging threat, without introducing a procedure that would define a schedule of actions ensuring regular testing, measuring, and evaluating the effectiveness of the implemented measures is insufficient. The Company, as evidenced by the collected material, despite the adopted solutions, was unable to detect vulnerabilities due to the lack of regular tests of the system implemented by the Company (...) Therefore, it is impossible in this context to challenge the assessment of the President of the UODO that regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of processing is a fundamental obligation of every administrator and processor arising from Article 32(1)(d) of the GDPR (...)" Similarly, in the judgment of June 6, 2023, case file II SA/Wa 1939/22, the WSA indicated that "(...) the obligation of regular testing of technical and organizational measures, securing the processing of personal data, to ensure a level of security corresponding to the risk, in the understanding of Article 32(1) introductory sentence of the GDPR, arises directly from the wording of point (d) of the indicated Article 32(1) (...)". The WSA expressed a similar opinion in its judgment of June 21, 2023, case file II SA/Wa 150/23.

3. The necessity for ongoing verification of the effectiveness of the security measures provided is particularly important in the case of processing personal data outside the area of the Administrator's organization. In this context, it should be emphasized that the proper implementation by the Administrator of the obligation arising from Article 32(1)(d) of Regulation 2016/679 would allow for the detection that the requirement specified in point 13 of the "Instruction for Managing IT Systems Used

for Processing Personal Data in J. (...) SA" regarding the encryption of media used for processing personal data transferred outside the processing area is not being practically fulfilled.

4. In summary, the irregularities indicated above consequently constitute a violation by the Administrator of the obligations arising from Article 24(1) and Article 32(1) and (2) of Regulation 2016/679.

****Justification for the Imposition and Determination of the Amount of Administrative Fines****

5. According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of the measures referred to in Article 58(2) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the particular case. In light of the identified violation of the provisions of Regulation 2016/679, the President of the Office, exercising the authority granted to him under the aforementioned provision, determined that there were grounds for imposing an administrative fine on the Company. According to the content of Article 83(2) of Regulation 2016/679, administrative fines are imposed, depending on the circumstances of each individual case, in addition to or instead of the measures referred to in Article 58(2)(a)-(h) and (j) of Regulation 2016/679.

6. According to Article 83(4)(a) of Regulation 2016/679, a violation of the provisions shaping the obligations...

****Administrator and Processor****

The administrator and the processor referred to in Articles 8, 11, 25-39, as well as 42 and 43, are subject, in accordance with paragraph 2, to an administrative fine of up to 10,000,000 EUR, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable.

****Assessment of Circumstances Referred to in Article 83(2) of Regulation 2016/679****

28. In deciding to impose an administrative fine, the President of the Office – in accordance with Article 83(2)(a)–(k) of Regulation 2016/679 – took into account the circumstances of the case presented below (see points 29–32 of the justification of the decision), which necessitate the application of this type of sanction in the present case and affect the severity of the imposed administrative fine.

29. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them [Article 83(2)(a) of Regulation 2016/679]. The infringement of the provisions of Articles 32(1) and (2) of Regulation 2016/679 by the Company in connection with the processing of personal data within the framework of its activities involving the editing, preparing, creating, or publishing of press materials, without implementing appropriate technical and organizational measures based on a conducted risk analysis, has significant gravity, due to the nature of the activities it performs, and thus the potential scope of data processing. It should be noted that the Company's activities are not limited solely to conducting (...) of a regional nature. The website operated by the Company, [www\(...\).pl](http://www(...).pl), has a reach greater than local. Thanks to the internet, the site is globally accessible, allowing it to be visited and its resources used from various parts of the world. Although the main recipients of the content (...) may be residents of M. and the surrounding areas, the reach of the website is not limited solely to this region. The website can be visited by users from both Poland and abroad who are interested in content related to this region. Particularly, however, thanks to search engines and widely available translators, this site is currently accessible to practically everyone, everywhere. Such a nature of processing is associated with significantly greater risks for the individuals whose data is concerned and means that the infringement of the provisions of Regulation 2016/679 is serious and significant. The press information generated by the Company can reach an unlimited number of recipients, which consequently creates a higher risk associated with the processing of personal data in the event of a security breach of that data. The lack of a procedure for verifying press materials before their publication, in terms of the personal data contained therein, entails the risk of unauthorized disclosure and use of that data against the will of the individuals whose

data is concerned. Furthermore, due to the nature of the activities and the scope of data processing, in the event of an infringement, its removal and mitigation of any negative effects may be impossible to achieve. It should be emphasized that the Company is (...) and, in connection with its activities, is expected to apply higher standards, and above all, due diligence in the context of personal data processing (see (...) especially regarding the obligations arising from the mission of public media and the duty of responsibility for the word). The identified infringement of personal data protection regulations in this case creates a high risk of negative consequences for every individual who is of interest to the Company (...). Moreover, the lack of procedures for verifying press material before its publication regarding the personal data to be disclosed may lead to the identification of the individual to whom that data pertains and to its further dissemination through mass media. Consequently, this may result in damages for that individual, both of a material and non-material nature, and even physical harm. It is also significant that the processing of data in violation of the provisions of Regulation 2016/679 has been occurring since the date of the commencement of the application of the provisions of Regulation 2016/679, i.e., since May 25, 2018, and continues to this day. It thus has a continuous and prolonged nature, thereby posing more serious threats in the area of privacy violations for individuals whose data and information concerning them may have been published by the Company during this time, and whose identification may occur under various circumstances even in the future.

30. The unintentional nature of the infringement [Article 83(2)(b) of Regulation 2016/679]. According to the Guidelines 04/2022 on calculating administrative fines under the GDPR (hereinafter referred to as Guidelines 04/2022), "[i]n principle, 'intent' encompasses both knowledge and deliberate action, in relation to the characteristics of the prohibited act, while 'negligence' means the absence of intent to cause an infringement, despite the failure of the administrator/processor to fulfill the due diligence required by law." The evidence indicates that the Company was aware of its obligations to implement appropriate security measures for data processing in relation to the risk of infringement of rights or freedoms, as directly evidenced by the content presented during the document control (see point 2 i 15-16 of the reasoning of the decision). Nevertheless, the provisions contained in the Company's documentation have not been implemented by it (see point 16 of the reasoning of the decision), in particular, a risk analysis was not conducted, encryption of storage devices containing personal data was not performed, which devices were used outside the processing area, and reviews of the adopted security measures regarding their relevance to the current operations of the Company were not carried out (see points 17-18 and 22 of the reasoning of the decision). Such behavior of the Company indicates a lack of sufficient knowledge about the risks arising from the processing of personal data and the consequences of these risks for the individuals concerned, primarily due to the lack of a risk assessment. Potential risks include, among others, data loss, unauthorized access to data, and their modification. According to the supervisory authority, the violation of the provisions of Regulation 2016/679 results from the Company's negligence and should be assessed as an unintentional violation.

31. Degree of cooperation with the supervisory authority in order to rectify the violation and mitigate its potential negative effects [Article 83(2)(f) of Regulation 2016/679]. In relation to the identified violation of the provisions of Regulation 2016/679 indicated in the notification of the initiation of administrative proceedings, the Company did not take any actions aimed at improving the state of protection of the data processed by it. As indicated by the European Data Protection Board (hereinafter referred to as "EDPB") in Guidelines 04/2022 (p. 31), "the ordinary obligation of cooperation is mandatory and should therefore be regarded as a neutral (not mitigating) circumstance. However, if cooperation with the supervisory authority resulted in limiting or avoiding negative consequences for the rights of individuals, which consequences could otherwise occur, the supervisory authority may consider this as a mitigating circumstance within the meaning of Article 83(2)(f) of the GDPR, resulting in a reduction of the monetary penalty. This may be the case, for example, when the controller or processor responded in a specific manner to the requests of the supervisory authority during the investigation phase in this particular case, which consequently significantly limited the impact on the rights of the data subjects." The lack of response from the Company to the requests of the authority, in this case regarding the

violation of the provisions of Regulation 2016/679 identified in the notification of the initiation of administrative proceedings (see point 3 of the reasoning of the decision), cannot therefore be regarded as neutral, let alone as mitigating in the context of the imposition of an administrative monetary penalty.

32. Categories of personal data affected by the violation [Article 83(2)(g) of Regulation 2016/679]. Given that the subject of the Company's activity is press activity involving the editing, preparation, creation, or publication of press materials, which may include any information about an identified or identifiable natural person, it should be assumed that the violation of the provisions of Regulation 2016/679 indicated in this decision concerns all data processed by the Administrator, including special categories of data specified in Article 9(1) and Article 10 of Regulation 2016/679. The nature of the activities performed by the Administrator indicates that it may lead to the publication of any information held by the Company that may allow for the identification of a specific person, including data that is subject to special protection under Regulation 2016/679. In this context, it is worth recalling the EDPB Guidelines 04/2022, which state: "Regarding the requirement to consider the categories of personal data affected by the violation (Article 83(2)(g) of the GDPR), the GDPR explicitly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of the GDPR and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are affected by the violation or the more sensitive the data is, the greater weight the supervisory authority may attribute to this factor. The quantity of data concerning each individual also matters, as the larger the amount of data concerning each individual, the greater the scale of the violation of the right to privacy and data protection."

33. In determining the amount of the administrative monetary penalty, the President of the Office found no grounds for considering mitigating circumstances that would affect the final amount of the penalty. All the criteria listed in Article 83(2)(a)-(j) of Regulation 2016/679, in the opinion of the supervisory authority, constitute either aggravating circumstances or merely neutral ones. Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires consideration of any other aggravating or mitigating factors applicable to the circumstances of the case), no mitigating circumstances were found, only neutral ones.

34.

Here is the translation of the provided legal document text into English:

Other than the circumstances specified below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified violation in this case, were deemed neutral in the President of the Office's assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

a) Actions taken by the controller to minimize the damage suffered by the data subjects [Article 83(2)(c) of Regulation 2016/679]. During these proceedings, no evidence was collected that would unequivocally demonstrate the existence of a causal link, that the violation of the provisions of Regulation 2016/679 identified in this decision caused damage to the data subjects.

b) The degree of responsibility of the controller, taking into account the technical and organizational measures implemented by it under Article 32 [Article 83(2)(d) of Regulation 2016/679]. As indicated by the EDPB in Guidelines 04/2022, when considering the aforementioned criterion, "the supervisory authority must answer the question of the extent to which the controller 'did everything that could be expected,' given the nature, purposes, or scope of processing and in light of the obligations imposed on it by the regulation." The President of the Office found that the Company violated the provisions of Article 32(1) and (2) of Regulation 2016/679. In the supervisory authority's assessment, the controller bears a high degree of responsibility for failing to implement appropriate technical and organizational

measures aimed at ensuring the security of personal data processing in connection with conducting activities related to editing, preparing, creating, or publishing press materials. The national legislator, in order to reconcile the right to personal data protection with the freedom of expression and information, introduced exceptions to the application of the requirements of Regulation 2016/679 to journalistic activities by excluding, among others, the application of processing principles or the realization of rights of data subjects, not without reason left the burden on such a controller to implement technical and organizational measures that ensure the security of processing data appropriate to the risk of infringement of the rights or freedoms of natural persons. Considering the scope of mass media ((...)) and the website available at [https://\(...\)pl](https://(...)pl), the nature of the materials presented therein, and the unlimited number of recipients, the technical and organizational measures must ensure the secure management of information constituting personal data, thus serving to ensure a balance between the protection of personal data and freedom of expression. Given the identified violation of the provisions of Regulation 2016/679, it is evident that the controller did not "do everything that could be expected of it"; thus, it did not fulfill the obligations imposed on it by the provisions of Article 32 of Regulation 2016/679. In this case, this circumstance constitutes the essence of the violation itself and is not merely a factor influencing—aggravating or mitigating—its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Article 32 of Regulation 2016/679 cannot be considered in this case as a circumstance that could additionally influence the assessment of the violation and the amount of the administrative monetary penalty imposed on the Company.

c) Relevant previous violations of the provisions of Regulation 2016/679 by the controller [Article 83(2)(e) of Regulation 2016/679]. The President of the Office did not find any previous violations of personal data protection regulations committed by the Company, which means there are no grounds to treat this circumstance as aggravating. The lack of previous violations does not have a mitigating effect on the assessment of the violation made by the President of the Office, as compliance with personal data protection regulations is a natural state resulting from the legal obligations imposed on the controller.

d) The manner in which the supervisory authority became aware of the violation, in particular, whether and to what extent the controller reported the violation [Article 83(2)(h) of Regulation 2016/679]. The President of the Office found that the Company violated personal data protection regulations as a result of a conducted compliance audit of data processing with data protection regulations. As indicated by the EDPB in Guidelines 04/2022 (p. 31), "According to Article 83(2)(h), the manner in which the supervisory authority became aware of the violation may constitute a significant aggravating or mitigating factor. In assessing this aspect, particular importance can be attributed to the question of whether the controller or processor notified the violation on its own initiative, and if so, to what extent, before the supervisory authority was informed of the violation through—for example—a complaint or investigation. [...] In cases where the supervisory authority became aware of the violation, for example, as a result of a complaint or during proceedings, this element should generally also be considered a neutral circumstance."

e) Compliance with previously applied measures in the same case, referred to in Article 58(2) of Regulation 2016/679 [Article 83(2)(i) of Regulation 2016/679].

Please let me know if you need any further assistance!
Regulation 2016/679].

Before issuing this decision, the President of the Office did not apply any measures referred to in Article 58(2) of Regulation 2016/679 against the Company in the matter under consideration, which means that the controller was not obliged to take any actions related to their application, and such actions, assessed by the President of the Office, could have had an aggravating or mitigating effect on the assessment of the established infringement.

f) The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 [Article 83(2)(j) of Regulation

2016/679]. The Company does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for controllers and processors, as stipulated by the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered against the controller in this case. On the other hand, the circumstance of adopting and applying such instruments could be taken into account in favor of the Company as measures guaranteeing a higher than standard level of protection of personal data processing.

g) Other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the infringement or avoided losses [Article 83(2)(k) of Regulation 2016/679]. The President of the Office, comprehensively considering the case, did not note any circumstances other than those described above that could affect the assessment of the infringement and the amount of the imposed administrative fine. He did not find that the Company, as the controller, had gained any financial benefits or avoided such losses in connection with the infringement. Therefore, there are no grounds to treat this circumstance as aggravating.

35. Taking into account all the circumstances discussed above, the President of the Office concluded that the imposition of an administrative fine on the Company is necessary and justified by the gravity, nature, and scope of the alleged infringement of the provisions of Regulation 2016/679. It should be stated that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the Company would not commit further negligence in the future.

36. Regarding the amount of the administrative fine imposed on the Company, it should be noted that in the established circumstances of this case, given the identified infringement of the obligations specified in Article 32(1) and (2) of Regulation 2016/679, Article 83(4)(a) of Regulation 2016/679 applies, according to which the infringement of the indicated provisions is subject to an administrative fine of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable.

Calculation of the administrative fine according to Guidelines 04/2022.

37. The President of the Office applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022 to determine the amount of the administrative fine in this case.

38. The President of the Office categorized the identified infringement of the provisions of Regulation 2016/679 in this case (see Chapter 4.1 of Guidelines 04/2022). The infringement of Article 32(1) and (2) of Regulation 2016/679 identified in this case falls – in accordance with Article 83(4)(a) of Regulation 2016/679 – into the category of infringements subject to a lower penalty of the two provided for in Regulation 2016/679 (with a maximum amount of up to EUR 10,000,000 or up to 2% of the total annual turnover of the enterprise from the previous financial year). It has therefore been considered in abstracto (irrespective of the individual circumstances of the specific case) by the EU legislator as less serious than the infringements indicated in Article 83(5) of Regulation 2016/679.

39. The President of the Office assessed the infringement identified in this case as a violation of medium severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the factors listed in Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the infringement (constituting the "seriousness" of the infringement) were taken into account, namely: the nature, gravity, and duration of the infringement (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the infringement (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the infringement (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted that the consideration of their combined impact on the assessment of the infringement identified in this case...

in the case of the violation treated in its entirety leads to the conclusion that the level of its seriousness (understood in accordance with Guidelines 04/2022) is medium. Consequently, the starting amount for calculating the fine is accepted to be within the range of 10% to 20% of the maximum fine that can be

imposed on the Company (see Subsection 4.2.4 of Guidelines 04/2022). The President of the Office considered the starting amount of 1,500,000.00 EUR (equivalent to 6,313,800.00 PLN) to be appropriate and justified given the circumstances of this case.

40. The President of the Office adjusted the starting amount corresponding to the average seriousness of the established violation to the Company's turnover as a measure of its size and economic strength. According to the guidance of the European Data Protection Board presented in Chapter 4.3 point 65 of Guidelines 04/2022, in the case of enterprises with an annual turnover, as in this case, ranging from 2 to 10 million EUR, the supervisory authority may consider making further calculations of the fine based on an amount ranging from 0.3% to 2% of the starting amount. Considering that the total turnover (revenue) of the Company in 2023 (data obtained from two financial statements of the Company for the period from January 1, 2023, to December 28, 2023, and from December 29, 2023, to December 31, 2023) amounted to (...) PLN, which is (...) EUR (according to the average EUR exchange rate on January 28, 2025), the President of the Office deemed it appropriate to adjust the amount subject to calculations to a value corresponding to 0.75% of the starting amount, which is 11,250.00 EUR (equivalent to 47,353.50 PLN).

41. The President of the Office assessed the impact of other circumstances (besides those considered above in the assessment of the seriousness of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022) on the established violation. These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is, to the entity itself that committed the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. Considering the seriousness of the violation, the President of the Office recognized that an aggravating circumstance in this case is the degree of cooperation in order to remedy the violation (Article 83(2)(f) of Regulation 2016/679). The supervisory authority, in conducting the analysis in this case, did not take into account any mitigating circumstances that would affect the reduction of the penalty. Due to the existence of an aggravating circumstance in the case, the President of the Office, assessing its impact on the established violation, deemed it appropriate to increase the previously determined fine amount by 20% (see point 40 of the justification of the decision) – to the amount of 13,500 EUR (equivalent to 56,824.20 PLN).

42. The President of the Office considered that the fine amount determined in accordance with the above principles does not require further adjustment due to its effectiveness, the principle of proportionality, and its deterrent nature (Article 83(1) of Regulation 2016/679). In his assessment, the determined amount of the administrative fine, i.e., 56,824.20 PLN, will be effective (due to its severity, it allows achieving its repressive goal, which is to punish unlawful behavior), deterrent (it effectively discourages both the Company and other administrators from committing violations of the provisions of Regulation 2016/679 in the future), and proportional (it is adequate to the established seriousness of the violation, does not exceed the financial capabilities of the Company, and allows for achieving the objectives set out in Regulation 2016/679). The amount of 56,824.20 PLN (equivalent to 13,500 EUR) constitutes a threshold, above which further increases in the fine amount will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the fine amount could occur at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

43. According to the provisions of Article 103 of the Personal Data Protection Act, the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that in a given year the National Bank of Poland does not announce the average euro exchange rate on January 28 – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date. In 2025, the average euro exchange rate was announced by the National Bank of Poland on

January 28, 2025, at the rate of 1 EUR = 4.2092 PLN. Having this in mind, the President of the Office, based on Article 83(4)(a) of Regulation 2016/679 in conjunction with Article 103 of the Personal Data Protection Act, imposed on the Company – using the average euro exchange rate announced by the National Bank of Poland on January 28, 2025 (1 EUR = 4.2092 PLN) – an administrative fine in the amount of 56,824 PLN for the violation described in the operative part of this decision.

44. In the opinion of the President of the Office, the applied administrative fine fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case. In the opinion of the President of the Office, the administrative fine imposed on the Company is proportional, both to the seriousness of the violation (resulting in a breach of the data controller's obligations in implementing appropriate protective measures).

personal data), as well as the size of the administrator, which size – measured by its turnover – should be considered in an inseparable connection with regard to the effectiveness of the penalty and its deterrent character.

45. From the information presented by the Company, it follows that the total annual turnover from the previous financial year in 2023 amounted to (...) PLN (in words: (...)), which constitutes the equivalent of (...) EUR, according to the average euro exchange rate on January 28, 2025, whereby the amount of the administrative monetary penalty imposed in this administrative case constitutes approximately 0.3% of the total turnover of the Company in 2023. At the same time, it is worth emphasizing that the amount of the imposed administrative monetary penalty is only 0.135% of the maximum amount of the penalty that the President of the Office could impose on the Company for the violation identified in this case, in accordance with Article 83(4) of Regulation 2016/679. Considering the presented financial results, it must be stated that the imposed administrative monetary penalty will not be excessively burdensome for the Company. At the same time, the penalty will be effective (achieving the goal of punishing the administrator for the most serious violation with far-reaching consequences) and deterrent for the future.

46. The amount of the penalty has therefore been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, while on the other hand, does not lead to a situation in which the necessity to pay the administrative monetary penalty will result in negative consequences, in the form of a significant deterioration of the Company's financial situation. In the opinion of the President of the Office, the administrative monetary penalty will serve in these specific circumstances a repressive function, as it will be a response to the Company's violation of the provisions of Regulation 2016/679, but also a preventive function, as it will contribute to preventing future violations of the obligations of the data administrator arising from the data protection regulations. In the opinion of the President of the Office, the applied administrative monetary penalty meets the criteria mentioned in Article 83(1) of Regulation 2016/679 due to the seriousness of the identified violation in the context of the basic obligations of the administrator arising from Regulation 2016/679. The purpose of the imposed penalty is to ensure compliance by the Company with the provisions of Regulation 2016/679 in the future.

47. In light of the above, the President of the Personal Data Protection Office, based on Article 83(4)(a) of Regulation 2016/679 in connection with Article 103 of the Act of May 10, 2018 on the protection of personal data, for the violation described in the operative part of this decision, imposed on the Company – applying the average euro exchange rate on January 28, 2025 (1 EUR = 4.2092 PLN) – an administrative monetary penalty in the amount of 56,824 PLN (in words: fifty-six thousand eight hundred twenty-four zlotys), which constitutes the equivalent of 13,500 EUR. Having taken the above into account, the President of the Personal Data Protection Office decided as stated in the operative part of this decision.

Print article

Metadata

Providing entity:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2025-03-06

Information entered by:

Grzegorz Cześnik

2025-03-28 13:07:03

Last modified by:

Grzegorz Cześnik

2025-03-28 13:15:50